ENTREGA - LABORATORIO SCA

OWASP Dependency-Check, CycloneDX, Dependency-Track, DefectDojo y GitHub Actions

Repositorio: MasterJD/Laboratorio-SCA_17001625
Pull Request #1 fusionado en main
Commit de remediación: c94cb003a855d42f1dafdf30da179302dde8affd

1. Identificación del proyecto

El proyecto implementa un flujo de análisis de composición de software (SCA) para detectar, documentar y remediar vulnerabilidades en dependencias Java. La corrección fue desarrollada en fix/sca-remediation y posteriormente integrada mediante el PR #1 en main.

2. Resultado final

La aplicación compiló correctamente con Maven. El análisis local remediado reportó 0 dependencias vulnerables y 0 vulnerabilidades. El workflow de GitHub Actions terminó exitosamente, generó el SBOM CycloneDX, publicó los reportes y envió el SARIF a GitHub Code Scanning.

• Compilación Maven: BUILD SUCCESS.

• Dependency-Check local: 0 vulnerabilidades.

• SBOM CycloneDX generado con 27 componentes.

• Artefactos remotos: dependency-check-reports y cyclonedx-sbom.

• La clave NVD se mantiene fuera del repositorio.

3. Enlaces externos

La ejecución remota puede verificarse en el repositorio y en GitHub Actions:

• PR #1: https://github.com/MasterJD/Laboratorio-SCA_17001625/pull/1

• Workflow: https://github.com/MasterJD/Laboratorio-SCA_17001625/actions/runs/41157102979

• Job Dependency-Check: https://github.com/MasterJD/Laboratorio-SCA_17001625/actions/runs/41157102979/job/124406200491

• Job SBOM: https://github.com/MasterJD/Laboratorio-SCA_17001625/actions/runs/41157102979/job/124406200325

• Code Scanning: https://github.com/MasterJD/Laboratorio-SCA_17001625/security/code-scanning

4. Evidencias visuales

Las capturas documentan el análisis local, el pipeline automatizado, la importación del SBOM en Dependency-Track y la integración del reporte con DefectDojo.

Dependency-Check local

Se ejecutó el análisis local utilizando la base NVD cacheada. Después de actualizar las dependencias, el reporte final confirmó cero vulnerabilidades.



org.cysecurity:JavaVulnerableLab:0.0.1-SNAPSHOT

Scan Information (show all):

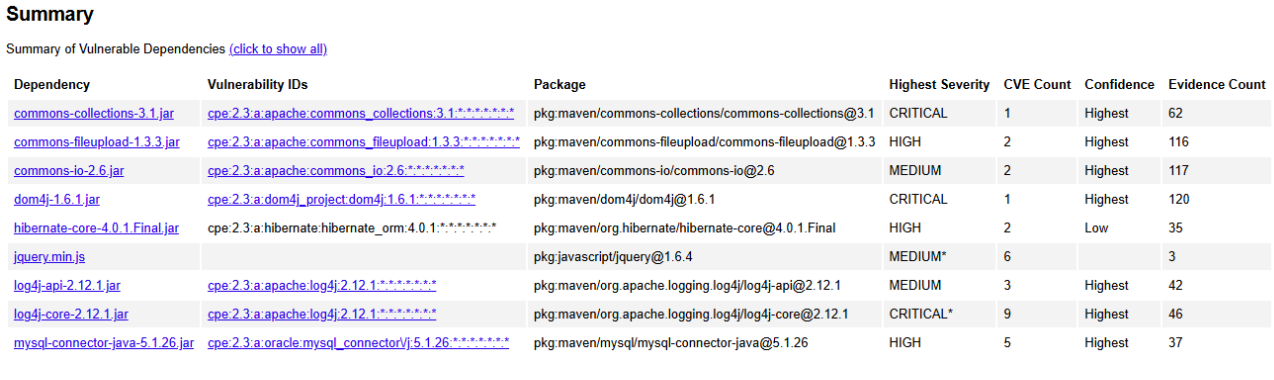
- *dependency-check version*: 13.0.0
- *Report Generated On*: Fri, 30 Oct 2026 07:21:39 GMT
- *Dependencies Scanned*: 21 (21 unique)
- *Vulnerable Dependencies*: 9
- *Vulnerabilities Found*: 31
- *Vulnerabilities Suppressed*: 0
- ...

Summary

Summary of Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
commons-collections-3.1.jar	cpe:2.3:a:apache:commons_collections:3.1:*:*:*:*:*:*:*	pkg:maven/commons-collections/commons-collections@3.1	CRITICAL	1	Highest	62
commons-fileupload-1.3.3.jar	cpe:2.3:a:apache:commons_fileupload:1.3.3:*:*:*:*:*:*:*	pkg:maven/commons-fileupload/commons-fileupload@1.3.3	HIGH	2	Highest	116
commons-io-2.6.jar	cpe:2.3:a:apache:commons_io:2.6:*:*:*:*:*:*:*	pkg:maven/commons-io/commons-io@2.6	MEDIUM	2	Highest	117
dom4j-1.6.1.jar	cpe:2.3:a:dom4j_project:dom4j:1.6.1:*:*:*:*:*:*:*	pkg:maven/dom4j/dom4j@1.6.1	CRITICAL	1	Highest	120
hibernate-core-4.0.1.Final.jar	cpe:2.3:a:hibernate:hibernate_orm:4.0.1:*:*:*:*:*:*:*	pkg:maven/org.hibernate/hibernate-core@4.0.1.Final	HIGH	2	Low	35
jquery.min.js		pkg:javascript/jquery@1.6.4	MEDIUM*	6		3
log4j-api-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.12.1	MEDIUM	3	Highest	42
log4j-core-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-core@2.12.1	CRITICAL*	9	Highest	46
mysql-connector-java-5.1.26.jar	cpe:2.3:a:oracle:mysql_connector\/j:5.1.26:*:*:*:*:*:*:*	pkg:maven/mysql/mysql-connector-java@5.1.26	HIGH	5	Highest	37

Ejecución local - captura 1

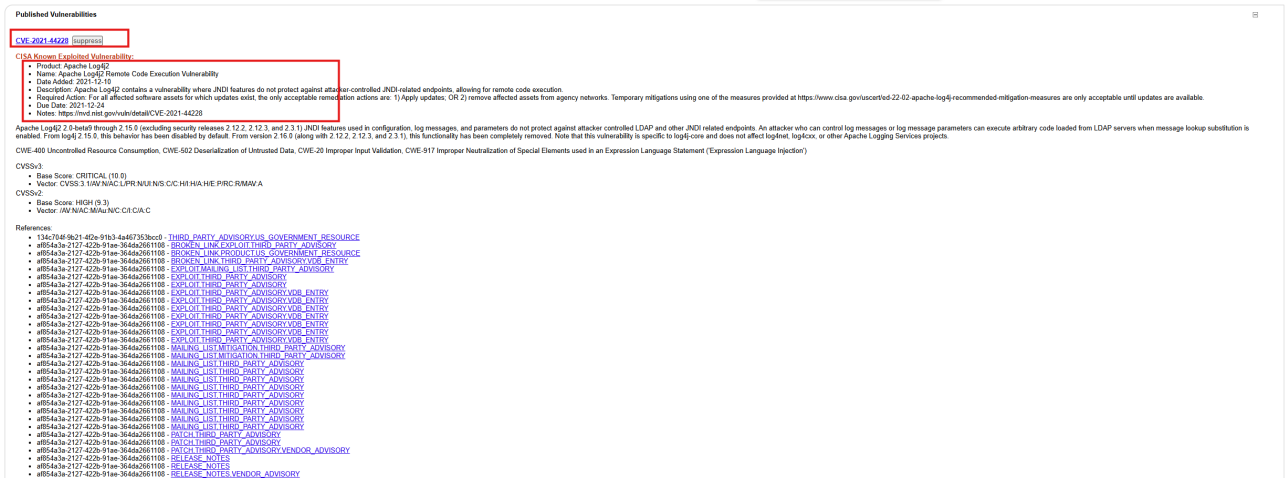


Summary

Summary of Vulnerable Dependencies (click to show all)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
commons-collections-3.1.jar	cpe:2.3:a:apache:commons_collections:3.1:*:*:*:*:*:*:*	pkg:maven/commons-collections/commons-collections@3.1	CRITICAL	1	Highest	62
commons-fileupload-1.3.3.jar	cpe:2.3:a:apache:commons_fileupload:1.3.3:*:*:*:*:*:*:*	pkg:maven/commons-fileupload/commons-fileupload@1.3.3	HIGH	2	Highest	116
commons-io-2.6.jar	cpe:2.3:a:apache:commons_io:2.6:*:*:*:*:*:*:*	pkg:maven/commons-io/commons-io@2.6	MEDIUM	2	Highest	117
dom4j-1.6.1.jar	cpe:2.3:a:dom4j_project:dom4j:1.6.1:*:*:*:*:*:*:*	pkg:maven/dom4j/dom4j@1.6.1	CRITICAL	1	Highest	120
hibernate-core-4.0.1.Final.jar	cpe:2.3:a:hibernate:hibernate_orm:4.0.1:*:*:*:*:*:*:*	pkg:maven/org.hibernate/hibernate-core@4.0.1.Final	HIGH	2	Low	35
jquery.min.js		pkg:javascript/jquery@1.6.4	MEDIUM*	6		3
log4j-api-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-api@2.12.1	MEDIUM	3	Highest	42
log4j-core-2.12.1.jar	cpe:2.3:a:apache:log4j:2.12.1:*:*:*:*:*:*:*	pkg:maven/org.apache.logging.log4j/log4j-core@2.12.1	CRITICAL*	9	Highest	46
mysql-connector-java-5.1.26.jar	cpe:2.3:a:oracle:mysql_connector\/j:5.1.26:*:*:*:*:*:*:*	pkg:maven/mysql/mysql-connector-java@5.1.26	HIGH	5	Highest	37

Ejecución local - captura 2



Published Vulnerabilities

CVE-2021-44228 suppress

CISA Known Exploited Vulnerability:

- Product: Apache Log4j2
- Name: Apache Log4j2 Remote Code Execution Vulnerability
- Date Added: 2021-12-10
- Description: Apache Log4j2 contains a vulnerability where JNDI features do not protect against attacker-controlled JNDI-related endpoints, allowing for remote code execution.
- Required Action: For all affected software assets for which updates exist, the only acceptable remediation actions are: 1) Apply updates; OR 2) remove affected assets from agency networks. Temporary mitigations using one of the measures provided at https://www.cisa.gov/uscert/ed-22-02-apache-log4j-recommended-mitigation-measures are only acceptable until updates are available.
- Due Date: 2021-12-24
- Notes: https://nvd.nist.gov/vuln/detail/CVE-2021-44228

Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled. From log4j 2.15.0, this behavior has been disabled by default. From version 2.16.0 (along with 2.12.2, 2.12.3, and 2.3.1), this functionality has been completely removed. Note that this vulnerability is specific to log4j-core and does not affect log4net, log4cxx, or other Apache Logging Services projects.

CWE-400 Uncontrolled Resource Consumption, CWE-502 Deserialization of Untrusted Data, CWE-20 Improper Input Validation, CWE-917 Improper Neutralization of Special Elements used in an Expression Language Statement ('Expression Language Injection')

CVSSv3:

- Base Score: CRITICAL (10.0)
- Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H/E:P/RC:R/MAV:A

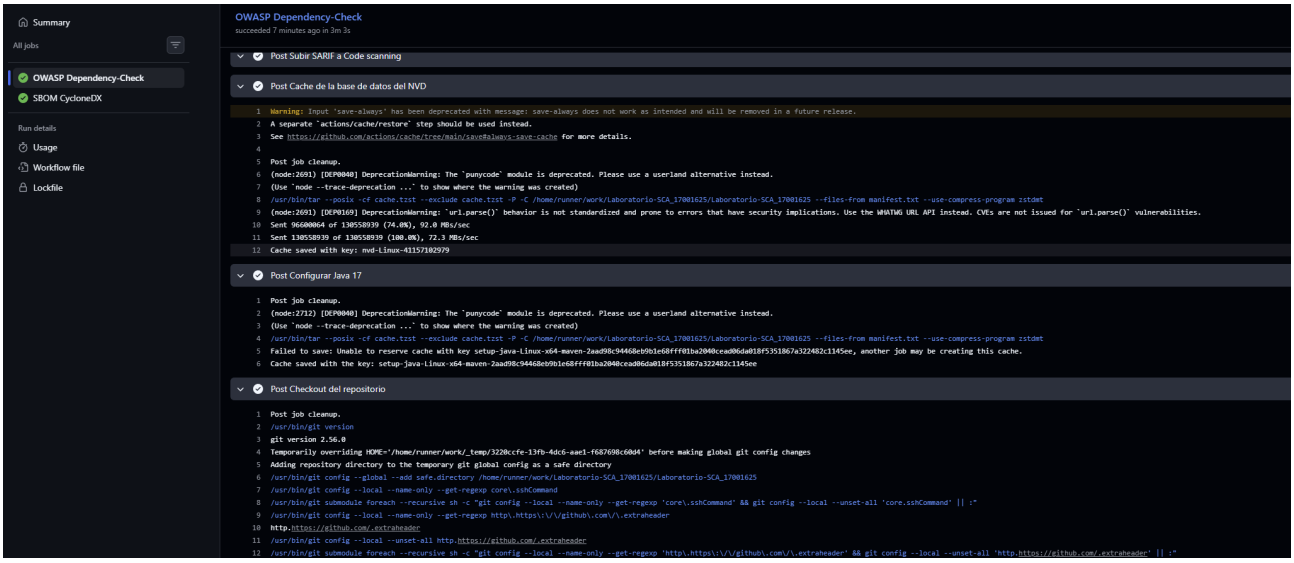
CVSSv2:

- Base Score: HIGH (9.3)
- Vector: /AV:N/AC:M/Au:N/C:C/I:C/A:C

References:

- 134c704f-9b21-4f2e-91b3-4a467353bcc0 - THIRD_PARTY_ADVISORY,US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK,EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK,PRODUCT,US_GOVERNMENT_RESOURCE
- af854a3a-2127-422b-91ae-364da2661108 - BROKEN_LINK,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - EXPLOIT,THIRD_PARTY_ADVISORY,VDB_ENTRY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,MITIGATION,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,MITIGATION,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - MAILING_LIST,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - PATCH,THIRD_PARTY_ADVISORY,VENDOR_ADVISORY
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES
- af854a3a-2127-422b-91ae-364da2661108 - RELEASE_NOTES,VENDOR_ADVISORY

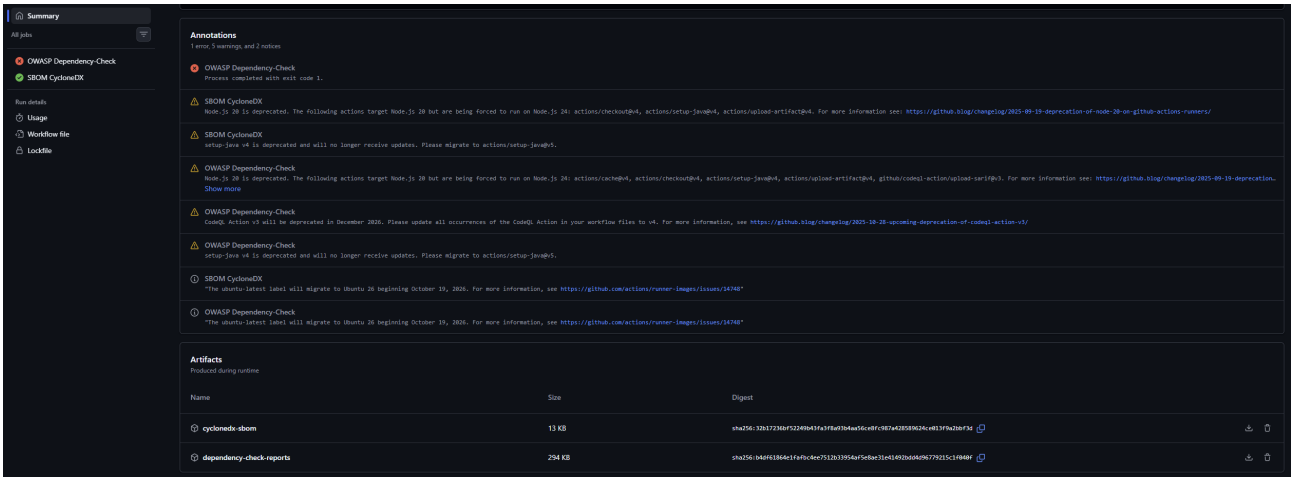
Ejecución local - captura 3



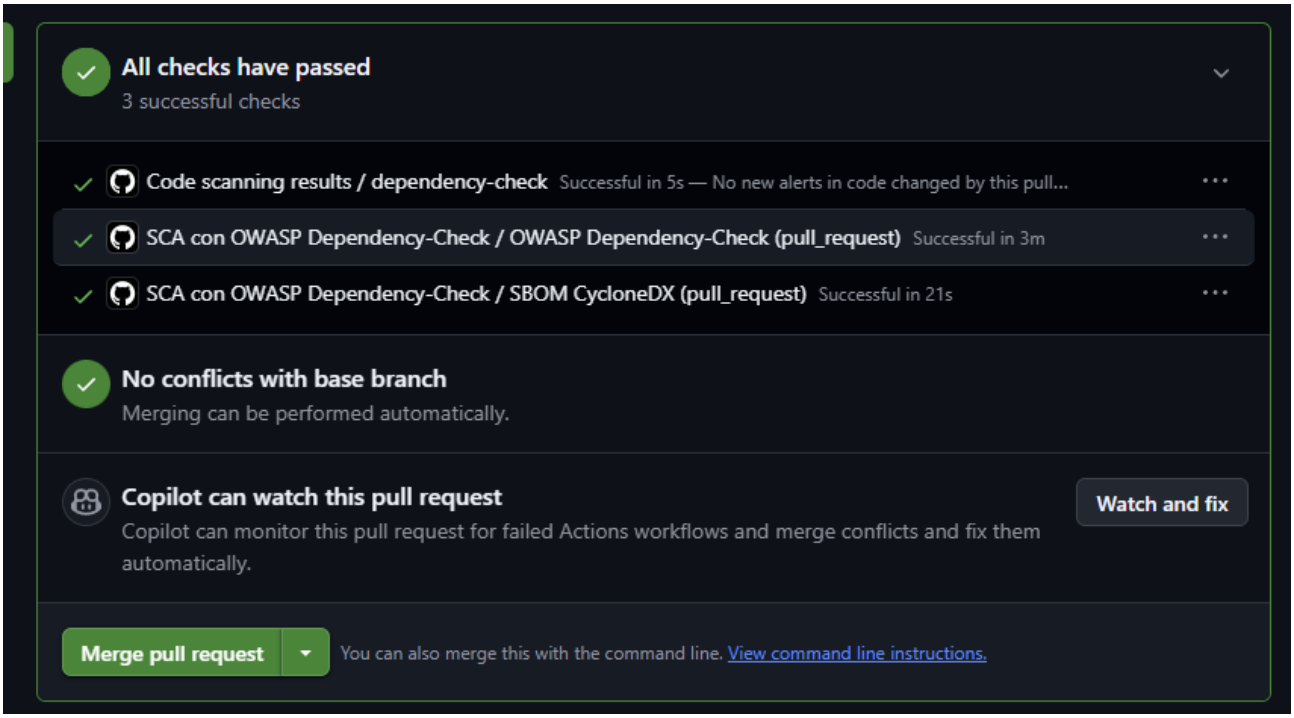
Resultado final sin vulnerabilidades

GitHub Actions y Pull Request

El workflow ejecuta Dependency-Check y CycloneDX automáticamente. El PR fue validado y fusionado en main.



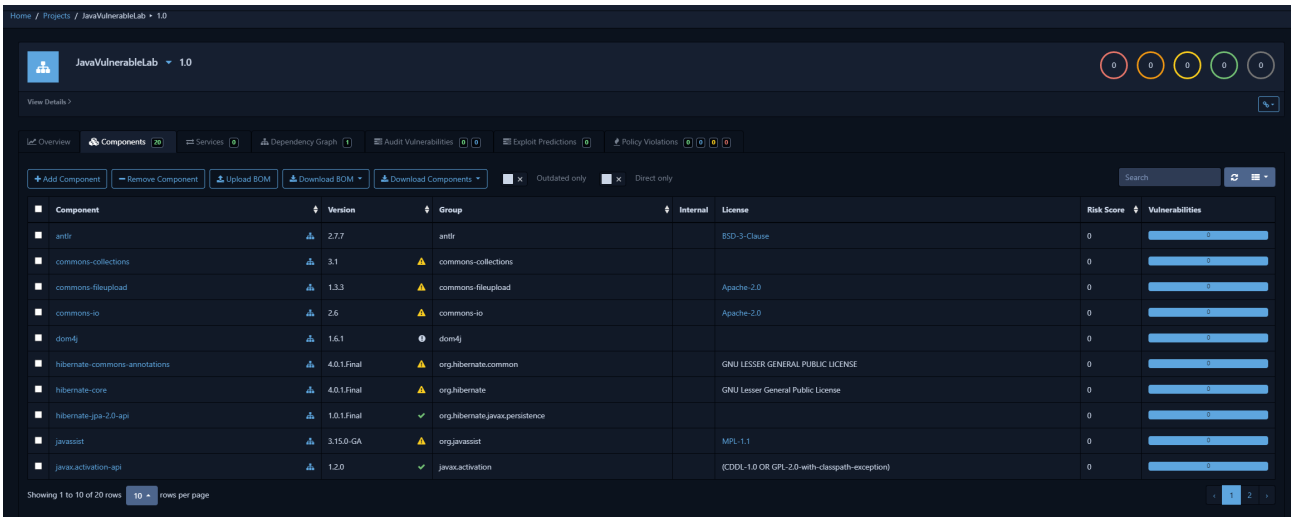
Ejecución exitosa del pipeline



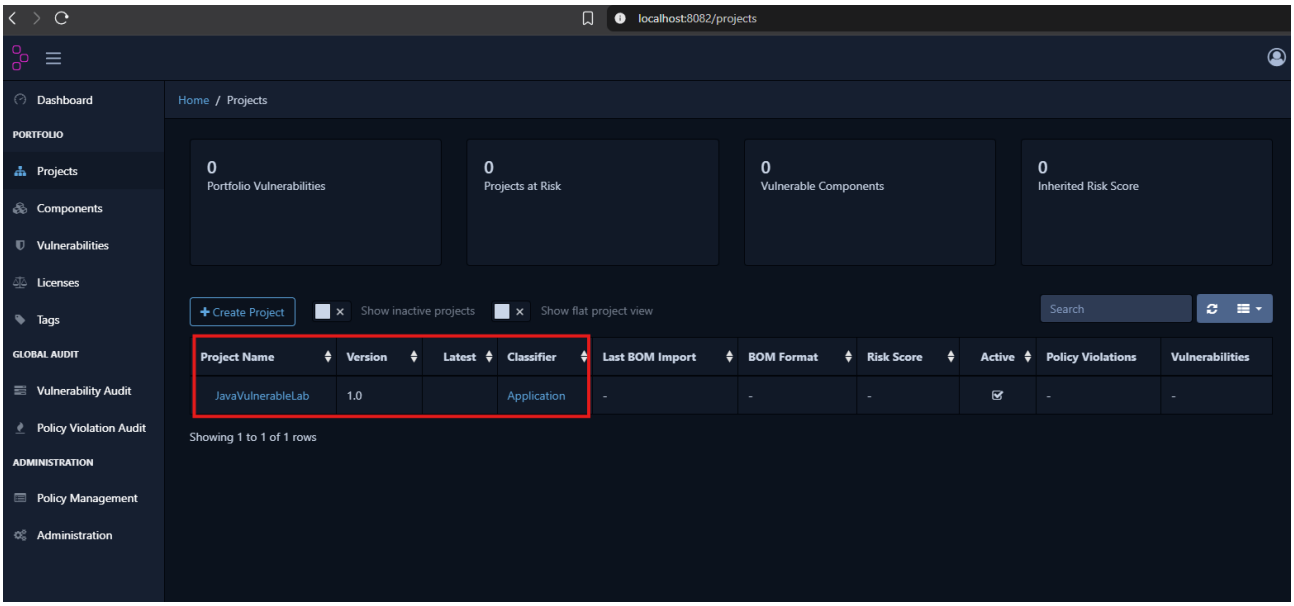
Pull Request fusionado

Dependency-Track

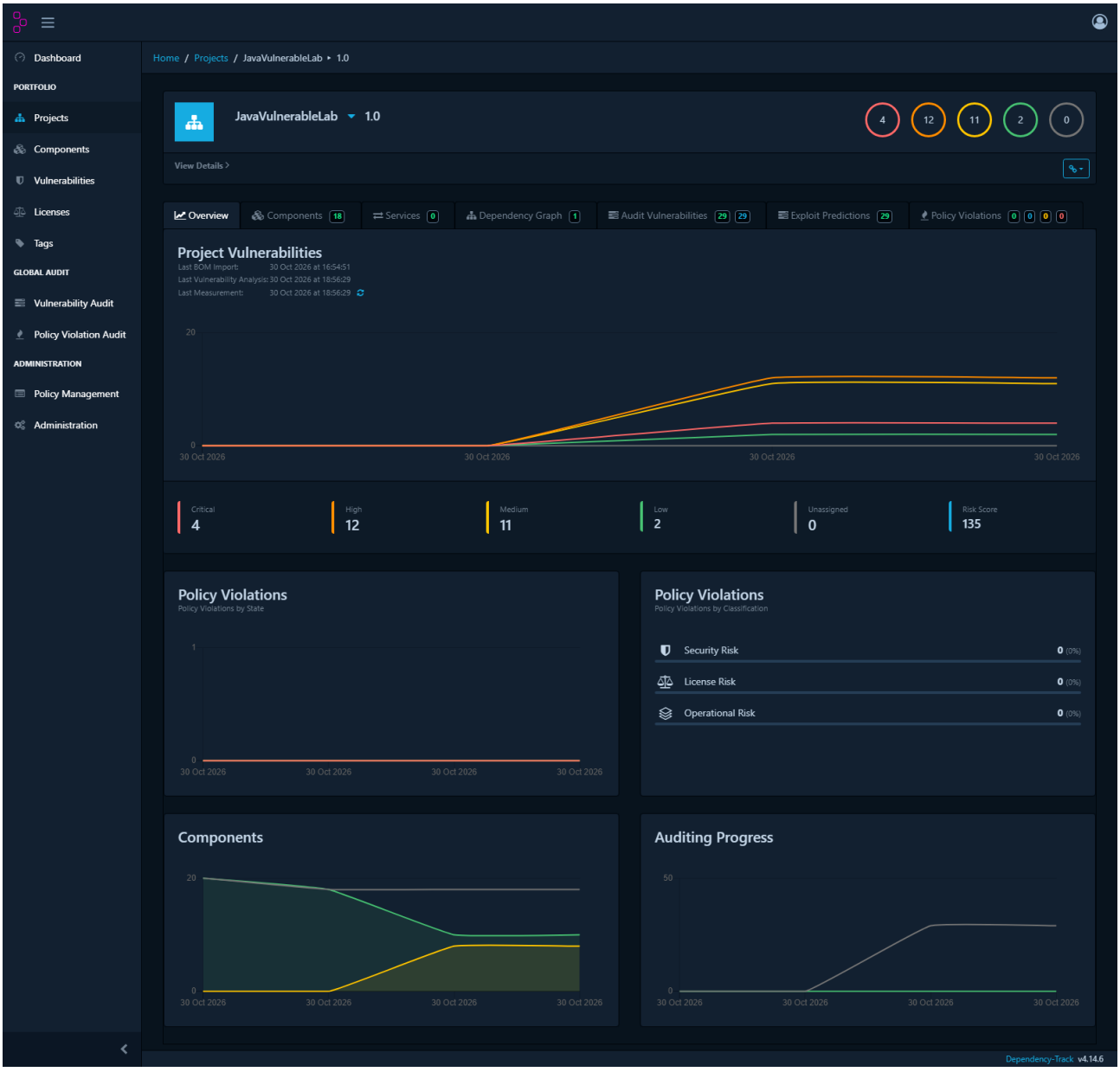
El SBOM se importó en Dependency-Track para revisar el inventario de componentes, la auditoría y el grafo de dependencias.



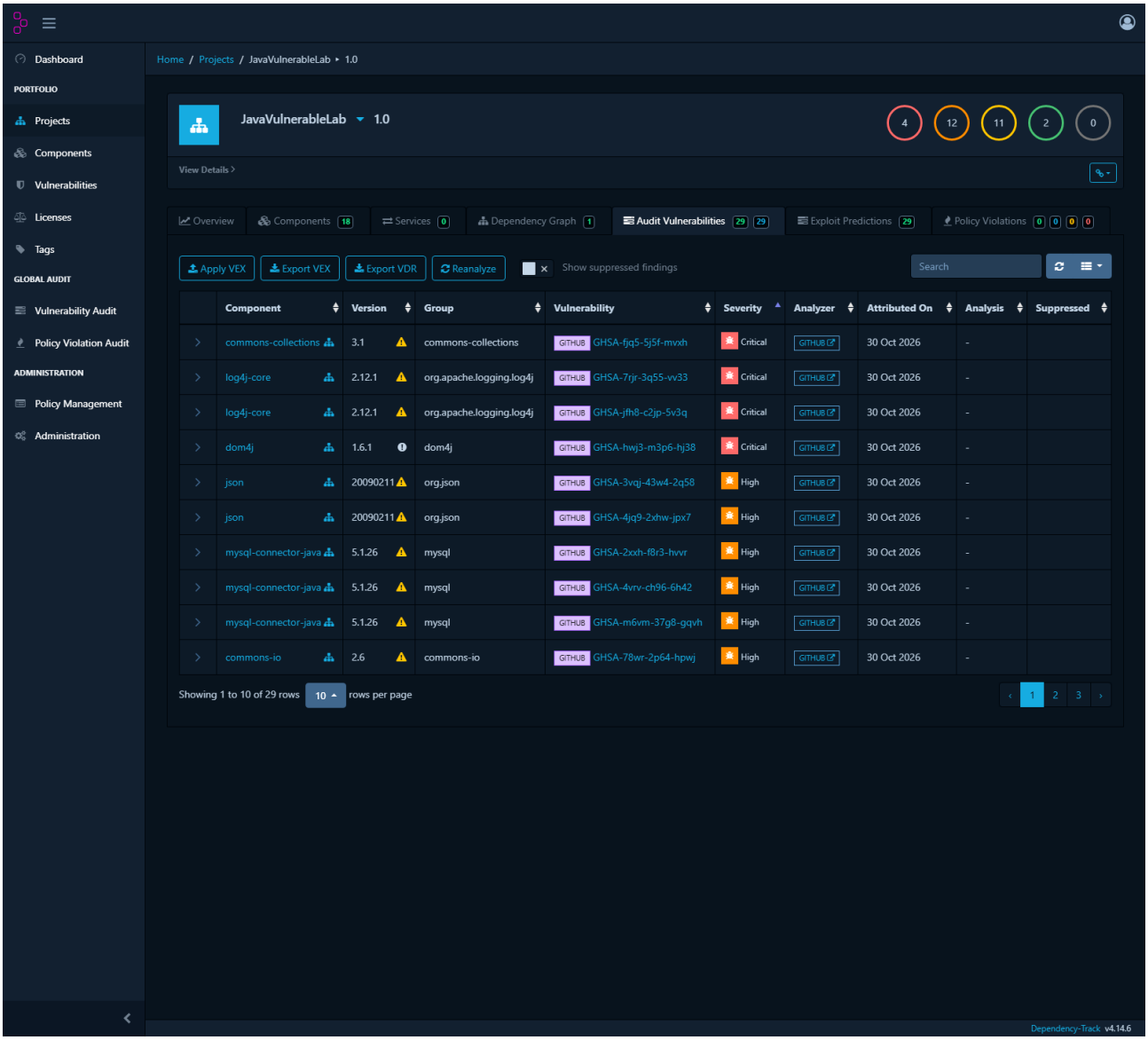
Importación del SBOM



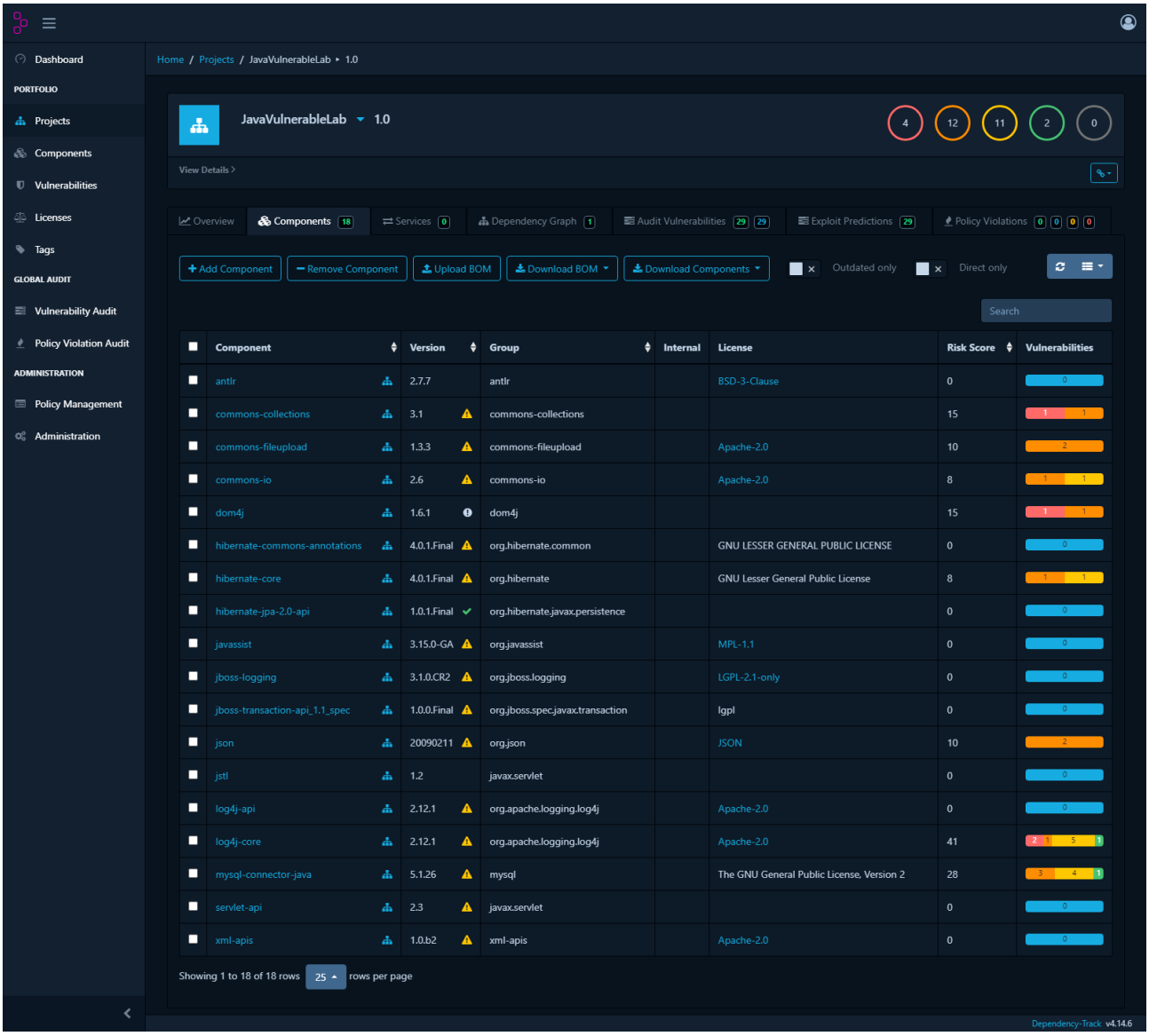
Proyecto JavaVulnerableLab



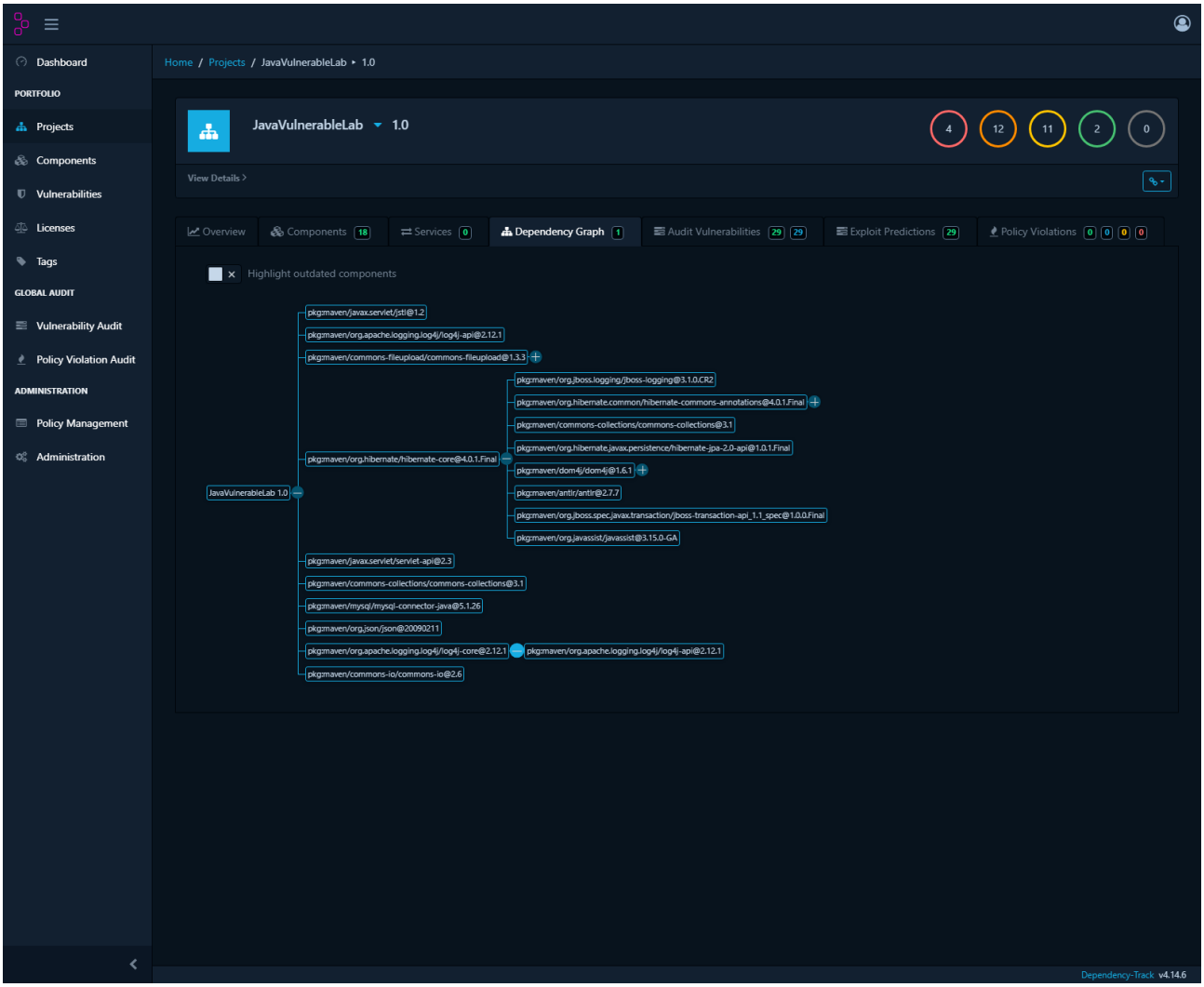
Vista general


Dashboard
PORTFOLIO
Projects
Components
Vulnerabilities
Licenses
Tags
GLOBAL AUDIT
Vulnerability Audit
Policy Violation Audit
ADMINISTRATION
Policy Management
Administration
Home / Projects / JavaVulnerableLab ▸ 1.0
JavaVulnerableLab 1.0
4 12 11 2 0
View Details >
Overview
Components 18
Services 0
Dependency Graph 1
Audit Vulnerabilities 29 29
Exploit Predictions 29
Policy Violations 0 0 0 0
Apply VEX
Export VEX
Export VDR
Reanalyze
Show suppressed findings
Search
Component
Version
Group
Vulnerability
Severity
Analyzer
Attributed On
Analysis
Suppressed
commons-collections 3.1 commons-collections GITHUB GHSA-fjq5-5j5f-mvxh Critical GITHUB 30 Oct 2026 -
log4j-core 2.12.1 org.apache.logging.log4j GITHUB GHSA-7rjr-3q55-vv33 Critical GITHUB 30 Oct 2026 -
log4j-core 2.12.1 org.apache.logging.log4j GITHUB GHSA-jfh8-c2jp-5v3q Critical GITHUB 30 Oct 2026 -
dom4j 1.6.1 dom4j GITHUB GHSA-hwj3-m3p6-hj38 Critical GITHUB 30 Oct 2026 -
json 20090211 org.json GITHUB GHSA-3vqj-43w4-2q58 High GITHUB 30 Oct 2026 -
json 20090211 org.json GITHUB GHSA-4jq9-2xhw-jpx7 High GITHUB 30 Oct 2026 -
mysql-connector-java 5.1.26 mysql GITHUB GHSA-2xxh-f8r3-hvvr High GITHUB 30 Oct 2026 -
mysql-connector-java 5.1.26 mysql GITHUB GHSA-4vrv-ch96-6h42 High GITHUB 30 Oct 2026 -
mysql-connector-java 5.1.26 mysql GITHUB GHSA-m6vm-37g8-gqvh High GITHUB 30 Oct 2026 -
commons-io 2.6 commons-io GITHUB GHSA-78wr-2p64-hpwj High GITHUB 30 Oct 2026 -
Showing 1 to 10 of 29 rows 10 rows per page
1 2 3
Dependency-Track v4.14.6

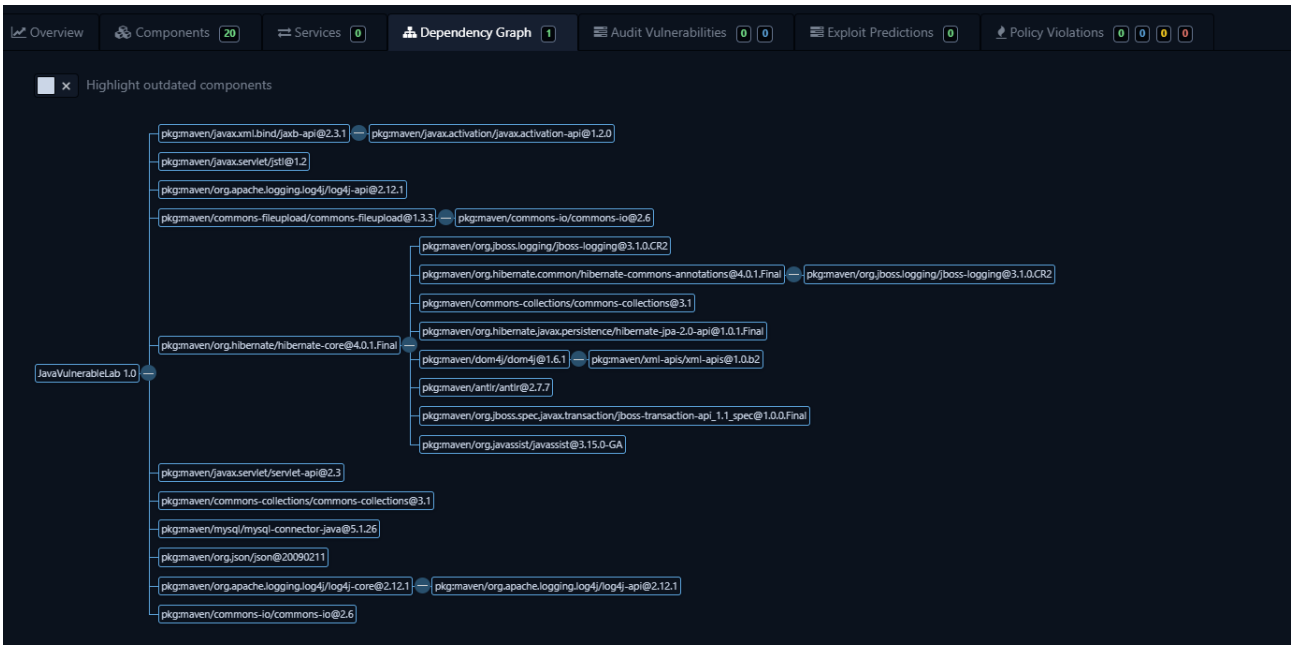
Auditoría



Componentes



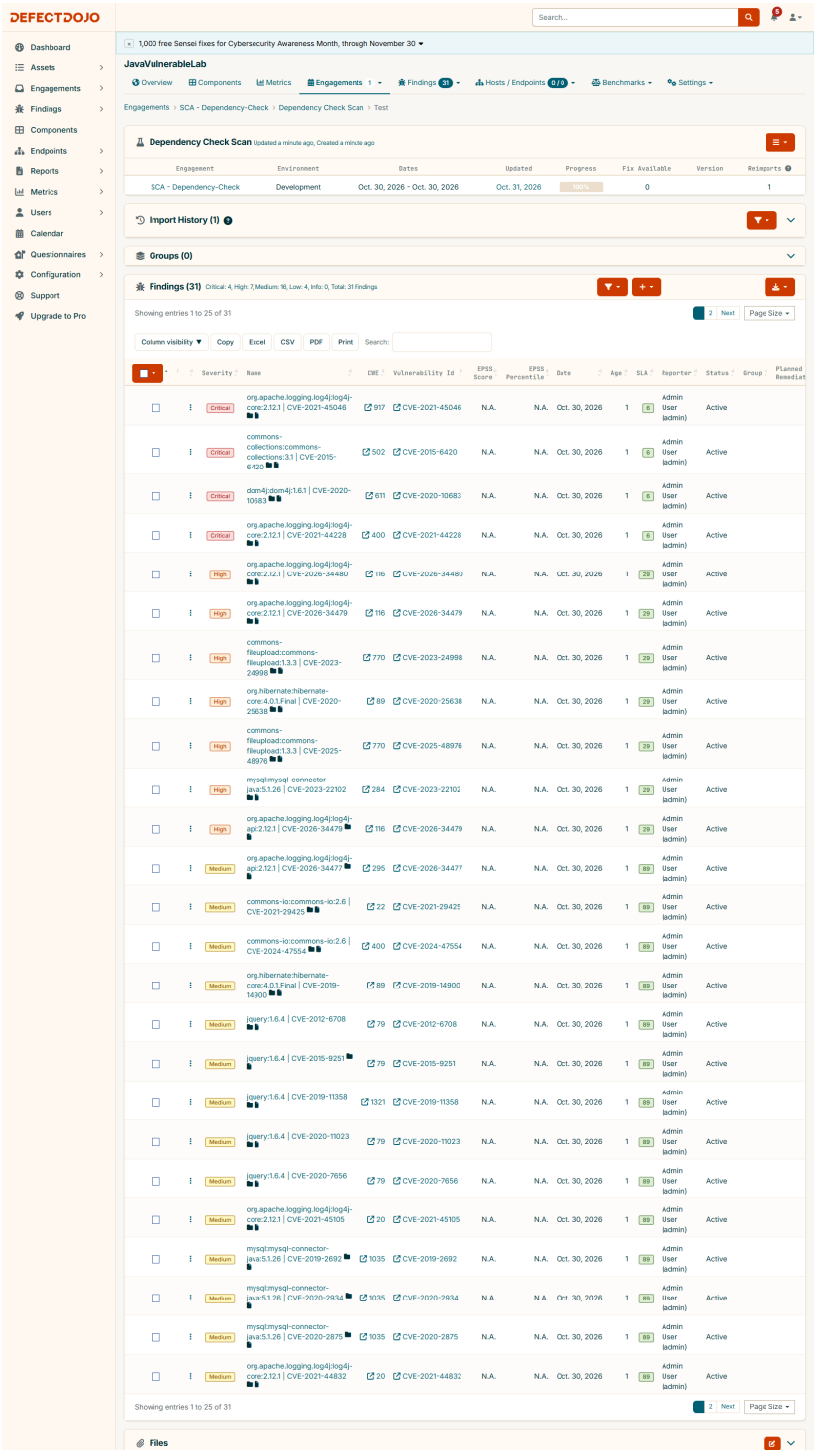
Grafo de dependencias



Grafo adicional

DefectDojo

El reporte XML de Dependency-Check se importó en DefectDojo como evidencia de integración con una plataforma de gestión de vulnerabilidades.



Importación del reporte en DefectDojo

5. Reportes y artefactos

El repositorio contiene el SBOM remediado y los reportes descargados del pipeline en HTML, JSON, XML y SARIF. El HTML facilita la lectura humana; JSON y XML permiten integraciones; SARIF alimenta Code Scanning.

- evidence/remediated-bom.json - SBOM CycloneDX de 27 componentes.
- evidence/remote-pipeline-dependency-check-reports/dependency-check-report.html
- evidence/remote-pipeline-dependency-check-reports/dependency-check-report.json

• evidence/remote-pipeline-dependency-check-reports/dependency-check-report.xml

• evidence/remote-pipeline-dependency-check-reports/dependency-check-report.sarif

6. Implementación y remediación

Se actualizó MySQL Connector/J a 8.4.0, protobuf-java a 3.25.5, JSON a 20231013, Hibernate a 5.6.15.Final, dom4j a 2.1.4, Log4j a 2.26.1, Commons Collections a 3.2.2, Commons FileUpload a 1.6.0, Commons IO a 2.16.1 y jQuery a 3.7.1. También se retiraron secretos simulados del código y se reforzó .gitignore.

7. Seguridad y archivos excluidos

No se publican .env.local, target/, reports/, datos persistentes de servicios, la copia local javavulnerablelab-sca/ ni el PDF original de instrucciones. La clave NVD se configura mediante secretos de GitHub y variables locales ignoradas.

8. Estado de la entrega

La implementación, el PR, el pipeline, el SBOM, las capturas y los reportes están incluidos en el repositorio. Este PDF y ENTREGA.md funcionan como índice y memoria técnica de la evidencia.